Evaluation

Context

This section gives you a clear view of the treatment(s) of personal data in question.

OVERVIEW

This part allows you to identify and present the object of the study.

What is the processing under consideration?

The '***RecruitSmart***' system is an AI-driven decision-support tool designed to streamline the initial stages of the recruitment process. The processing involves the automated extraction of professional skills, experience, and educational background from candidate CVs to generate a 'match-score' against specific job descriptions.
Distinct from a 'black-box' automated decision, the processing acts as a filtering layer to assist HR professionals. It includes two distinct phases:

Model Optimization: The training of the NLP (Natural Language Processing) model using a curated, pseudonymized historical dataset to ensure accuracy.

Operational Inference: The real-time analysis of new applicant data.
A critical component of this processing is the algorithmic fairness audit, ensuring the system does not reproduce historical biases related to gender, age, or origin

0 comment(s)

3/1/26

Comment

What are the responsibilities linked to the processing?

1. **Data Controller:** *Apex Datality Solutions Corp ADSC*

As the entity determining the "purposes and means," the Controller bears primary liability.

Key Responsibilities:

- Defining the legal basis for the AI (likely "Legitimate Interest" for screening).
- Conducting the final fairness audit to ensure the algorithm isn't discriminating.
- Managing Data Subject Rights (e.g., providing an explanation to a rejected candidate).
- Ensuring the "Human-in-the-Loop" remains active and trained.

2. **Joint Controller**: Apex Datality Group

And other Testers who used RecruitSmart across a group of companies where the global AI ethics policy was defined.

Key Responsibility: Determining the global parameters of the "success prediction" logic.

3. **Data Processor**: e.g., NeuralHire SaaS (The AI Software Provider)
This is the vendor providing the API or the cloud infrastructure.

Key Responsibilities (per GDPR Article 28):

1. Processing data strictly according to the Controller's written instructions.
2. Ensuring the security of the processing (encryption of CVs at rest/in transit).
3. Notifying the Controller of any data breaches within 72 hours.
4. AI-Specific: Ensuring the model does not "leak" training data via Model Inversion.

4. **Sub-Processors**: AWS France

Key Responsibility: Providing the physical/virtual servers where the CV data is stored. Reviewed and confirmed vetted for Data Residency (keeping the data within the EU/EEA to please the CNIL's international transfer rules).

The AI Ethics & Compliance Officer: Responsible for the periodic bias-testing of the RecruitSmart model. They act as the bridge between the DPO (Data Protection Officer) and the technical team to ensure "Privacy by Design."

0 comment(s)

3/1/26

Comment

Are there standards applicable to the processing?

Section 1.3: Standards & Certifications Applicable

1. Technical & Organizational Standards
2. ISO/IEC 42001:2023 (AI Management System):
3. ISO/IEC 27001: This confirms that the CV data is stored in an environment with world-class information security management.
4. ISO/IEC 24089

2. **Approved Codes of Conduct (CNIL/EU Specific)**

- The Cloud Infrastructure Service Providers (CISPE) Code of Conduct:
- Europrivacy.

3. **AI-Specific Ethical Frameworks**

- CNIL's Self-Assessment Guide for AI
- ALTAI (Assessment List for Trustworthy AI):
- NIST AI Risk Management Framework (AI RMF 1.0)

0 comment(s)

3/1/26

Comment

Evaluation

To correct

Acceptable

3/5/26

Evaluation comment

1. Final Risk Evaluation Summary

In the software's Evaluation or Validation tab, you must provide a consolidated view of the project's safety. For an AI recruitment tool, use this professional framing:

Risk Level Statement: "After implementing the Redaction Engine and RBAC controls, the residual risk of illegitimate access is considered Acceptable (Medium)."

Justification: "The severity is mitigated by Pseudonymization—even in a breach, match-scores cannot be linked to individuals without the master key. The likelihood is lowered by MFA and IP Whitelisting."

2. Mandatory AI Compliance Statements

The CNIL specifically looks for these two "AI-recommendable" declarations in the final assessment:

Human-in-the-Loop Confirmation: "The AI system is strictly a decision-support tool; no candidate is automatically rejected. Final hiring decisions are always made by a human recruiter."

Non-Discrimination Guarantee: "Regular Bias Audits are scheduled (Quarterly) to ensure the NLP scoring does not create disparate impact based on protected characteristics."

3. The Action Plan (Corrective Measures)

If any section was marked as "Improvable," you must attach a specific task.

Action 1: "Conduct Adversarial Red-Teaming (Model Inversion tests) before full production launch to verify the model's resistance to data extraction attacks."

CNIL

CNIL

+1

Action 2: "Provide 'Algorithmic Literacy' training to all HR staff by Q3 to ensure correct interpretation of AI match-scores."

wearenotch.com

wearenotch.com

4. Stakeholder Opinions

The CNIL methodology requires documenting the views of key figures before validation:

DPO Opinion: State that the Data Protection Officer has reviewed the Legal Basis (Legitimate Interest) and finds it proportionate.

Staff Representatives: If required by local labor law, note that the employee committee was consulted regarding the use of automated tools.

Final Step: Once you enter these, click "Ask for Validation" in the sidebar. This locks the version and prepares the official PDF report

Validate review

All fields must be filled

Data, processes and supporting assets »